Le Top 10 de l'OWASP (2021)

1 - Rupture de Control d'Accès (Broken Acces Control) : Les restrictions ne sont pas correctement mises en oeuvres pour empêcher les utilisateurs d'accéder aux comptes d'autres utilisateur, de voir des données sensibles, d'accéder à des fonctionnalités non-autorisés, de modifier des données, etc...

2 - Défaillance cryptographique (Cryptographique Failures) : Défaillances liés à la cryptographie qui conduisent souvent à l'exposition de donnée sensible ou à la compromission du system.

3 - Injection : Les données fournies par l'utilisateur ne sont pas validés, nettoyés filtrés par l'application. Quelques exemples sont : l'injection SQL, la command injection, l'injection LDAP...

4 - Conception non sécurisé (Insécure Design) : Les problèmes surviennent lorsque l'application n'est pas conçue en tenant compte de la sécurité.

5 - Mauvaises configuration de sécurité (Sécurity Misconfiguration) Manque de renforcement de la sécurité approprié sur n'importe quel partie de la pile applicative, configuration par défault non-sécurisé, stockage cloud ouvert, messages d'erreurs verbeux qui divulgent trop d'information

6 - Composants Vulnérables et Obsolètes (Vulnérable and Outdated Component) : Utilisation de composants (coté clients et coté serveurs) qui sont vulnérable non pris en charge et obsolètes.

7 - Défaillances d'Identification et d'Authentification (Identification and Authentification Failures) : Attaques liées à l'authentification qui ciblent l'identité de l'utilisateur, l'authentification et la gestion de sessions.

8 - Défaillance d'integrité des logiciels et des données (Software and Data Integrity Failures) Cette catégorie sont les défaillances d'intégrités des logiciels et des données concernant le code et l'infrastructure qui ne protègent pas contre les violations d'intégrités. Un exemple de cela est lorsque une application s'appuie sur des plugins, des bibliothèques ou modules provenant de sources, de dépot et de réseaux de diffusion de contenu (CDN) non fiables.

9 - Défaillance de journalisation et de surveillance de la sécurité (Sécurity logging and monitoring failures) : Cette catégorie vise a aider a detecter, a remonter et à repondre aux violations actives. Sans journalisations et surveillances les violations ne peuvent pas être détectés.

10 - Falsification de requêtes coté serveur (Server-Side Request Forgery ou SSRF) : Les failles SSRF se produisent chaque fois qu'une application web récupère une ressource a distance sans valider l'URL fournie par l'utilisateur. Cela permet à un attaquant de forcer l'application à envoyer une requête forgée vers une destination inattendue, même si elle est protégé par un pare-feu, un VPN ou tout autre liste de control d'accès réseau (ACL).

Il est essentiel de se familiariser avec chaque de ces catégories de vulnérabilités. Les vulnérabilités des applications Web seront traités plus profondément dans les modules ultérieurs.

→